

**INTERNATIONAL
CYBERSECURITY AND
DIGITAL FORENSICS
ACADEMY (ICDFA)**

**Governance, Compliance, and
Risk (GRC)**

GRC102: INFORMATION SECURITY GOVERNANCE

Week 2 Theory-Based

Assignment:

Principles of Information Security Governance

Student Name: ZUBAIR SUMAYYAH AJIKE

Reg. No: C11/26/CGRE/175962RCE/17596

9/10/2026

Task 1 Governance Blueprint

Executive request: The CEO requires a formal security governance structure with clear roles, reporting relationships and accountability following the recent near-miss.

Current Organisational Context

Employee / Role	Department	Relevant Context
John Smith – IT Manager	IT Operations	Manages infrastructure and performs some security activities.
Jane Doe – Senior Developer	Development	Leads a key product development team.
Mark Johnson – Compliance Officer	Legal & Compliance	Focuses on healthcare regulatory obligations.
Emily White – Data Analyst	Finance	Handles sensitive financial information.
Robert Green – HR Manager	Human Resources	Owns onboarding and offboarding processes.

Required Evidence Task 1

1. A current-state governance gap assessment identifying the most important weaknesses in GHC's ad-hoc model.
2. A proposed security governance organisational chart showing the Board, CEO, governance function and relevant business/technology relationships.
3. A RACI matrix covering at least six governance activities, including policy approval, risk review and incident response planning.
4. A short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management.

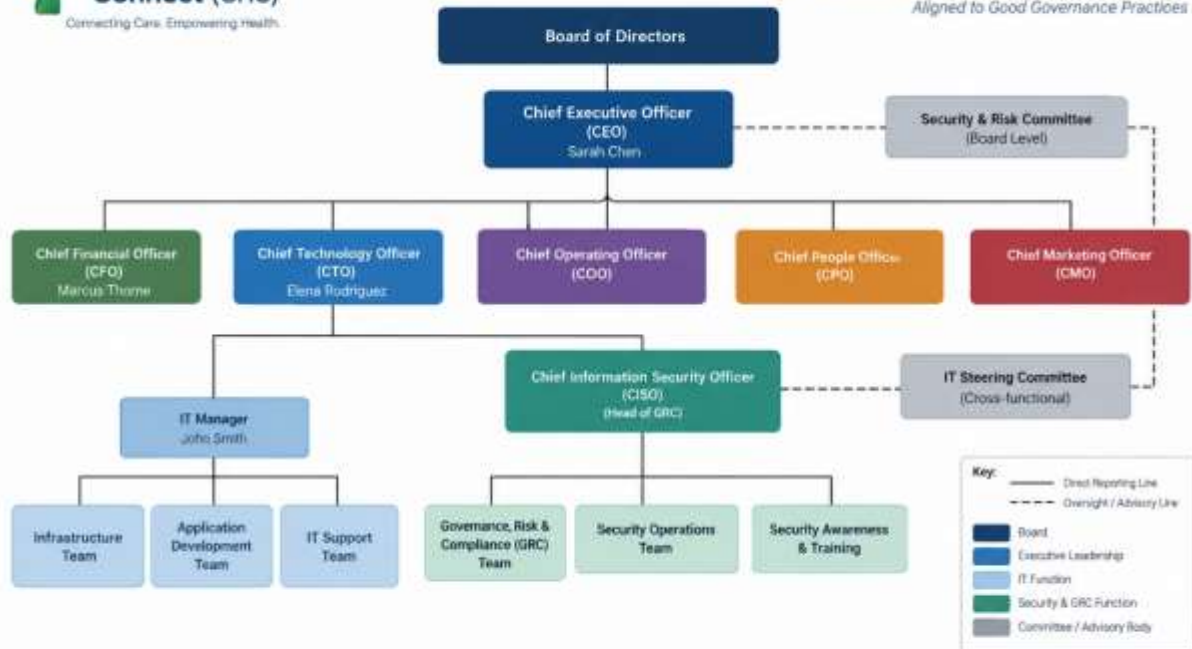
A current-state governance gap assessment identifying the most important weaknesses in GHC's ad-hoc model.

NO	GOVERNANCE AREA	CURRENT STATE AT GlobalHealth Connect (GHC) (Where we ARE)	GAP / FINDING (What is missing)	WHERE GlobalHealth Connect (GHC) NEEDS TO BE	PRIORITY	BENCHMARK
1	Governance Charter	No formal security governance charter.	Security mandate, authority and scope are not formally defined	Approved Information Security Charter defining mandate, authority and scope	H	ISO 27001 / COBIT

2	CISO/Dedicated Security Leader	Security activities are partly handled by IT	No dedicated security leadership or clear security accountability	Dedicated security leader responsible for security governance	H	ISO 27001
3	IT Steering Committee	Security decisions are handled informally	No formal cross-functional governance body	Formal committee for security, IT and business decisions	H	COBIT
4	GRC Function/Team	Compliance and security responsibilities are fragmented	No coordinated GRC function	Defined GRC function coordinating risk, compliance and governance	H	COBIT / ISO 27001
5	IT Governance Policies	Policies are inconsistent and inherited from acquisitions	Policies are outdated, inconsistent and not centrally governed	Approved, current and consistently applied governance policies	H	ISO 27001
6	Governance Framework(Adopted)	Governance approach is largely ad-hoc	No clearly adopted governance framework	Adopt and implement a structured governance framework	H	COBIT
7	Board Reporting On Security/IT	Technical information exists but is not consistently translated into business impact	Board lacks consistent business-focused security reporting	Regular Board reporting using meaningful risk and security metrics	H	COBIT / ISO 27001
8	RACI Matrix	Security ownership and accountability are unclear	Responsibilities are not formally assigned	RACI clearly defining Responsible, Accountable, Consulted and Informed roles	H	COBIT
9	Governance KPIS	Some technical metrics exist	Metrics are not consistently linked to business outcomes	Defined governance KPIs with targets and regular monitoring	M	COBIT / ISO 27001
10	Access Reviews	Access ownership and	No formal recurring			ISO27001

		review process are not clearly defined	access review process is evidenced	Periodic access reviews with clear ownership and evidence		
11	Security Awareness Training	Annual training is mandatory but engagement is low	Training effectiveness and engagement need improvement	Regular, measurable and role-based security awareness programme	H	ISO 27001
12	Incident Response Plan	GHC experienced a data-leakage near-miss	Formal response planning and escalation need strengthening	Documented and tested incident response plan with clear responsibilities	H	ISO 27001/NIST
13	Asset Inventory	Assets are not shown as being centrally governed	No complete, reliable inventory is evidenced	Maintained inventory of systems, information assets and ownership	H	ISO 27001
14	Vendor Risk Assessments	Third-party risk governance is not clearly established	Vendor security risks are not consistently assessed	Formal vendor risk assessment and monitoring process	M	ISO 27001
15	Risk Appetite Statement	Risk management is reactive	No formal statement defining acceptable security risk is evidenced	Board-approved risk appetite guiding security decisions and investments	H	ISO 27001 / COBIT

A proposed security governance organisational chart showing the Board, CEO, governance function and relevant business/technology relationships.



A RACI matrix covering at least six governance activities, including policy approval, risk review and incident response planning.

R = Responsible | A = Accountable | C = Consulted | I = Informed

Governance Activity	Board	CEO	CTO	CISO	Compliance Officer	GRC Team
1. Approve security policies	I	A	C	R	C	R
2. Define risk appetite	A	R	C	C	C	R
3. Conduct risk assessments	I	I	C	A	C	R
4. Incident response planning	I	I	C	A	C	R
5. Compliance monitoring	I	I	I	A	C	R
6. Board security reporting	A	C	C	R	C	R
7. Access reviews	I	I	C	A	C	R
8. Security awareness programme	I	A	C	R	C	R

Governance Activity	Board	CEO	CTO	CISO	Compliance Officer	GRC Team
9. Asset inventory governance	I	I	C	A	C	R
10. Vendor risk assessment	I	C	C	A	C	R
11. Governance KPI monitoring	I	C	C	A	C	R
12. IT/security budget approval	A	R	C	C	I	I

A short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management.

Activity	Why
Approve security policies	CEO is A because executive management owns organisational policy approval. CISO/GRC develop and manage the policy process.
Define risk appetite	Board is A because risk appetite is a strategic governance decision. CEO and CISO contribute to the decision/proposal.
Conduct risk assessments	CISO is A because they own the security risk-management programme. GRC Team performs the actual assessments.
Incident response planning	CISO is A because they own the security response programme. GRC Team develops and maintains the plan, while CTO provides technical input.
Compliance monitoring	CISO is A because compliance is part of the security governance programme. GRC Team performs monitoring and evidence collection.
Board security reporting	CISO is R for preparing the security report; Board is A for oversight of security governance.
Access reviews	CISO is A for the governance/control requirement; GRC Team performs the review and documents results.
Security awareness	CEO is A because organisation-wide participation requires executive ownership; CISO/GRC run the programme.
Asset inventory governance	CISO is A for security governance over assets; GRC Team maintains governance records, with CTO providing technical input.

Activity	Why
Vendor risk assessment	CISO is A for third-party security risk; GRC Team conducts the assessment.
Governance KPIs	CISO is A for security governance performance; GRC Team collects and tracks the metrics.
IT/security budget approval	Board is A for major organisational investment approval; CEO is R for proposing/owning the budget process.

Task 2 Information Security Charter

The CFO and Board require a formal mandate for the information security programme. Draft a concise but complete Information Security Charter that can be approved by executive management and referenced across the organisation.

GHC Strategic Goals for 2026

Strategic Goal	Business Intent
Expand Market Share	Increase the client base by 25% through new features and entry into two regional markets.
Enhance Operational Efficiency	Reduce overhead by 10% and improve system uptime to 99.99%.
Maintain Customer Trust	Protect patient information and aim for zero major data breaches.
Foster Innovation	Invest in AI-driven diagnostics and secure data-exchange capabilities.
Achieve Regulatory Excellence	Meet applicable healthcare and data-protection obligations proactively.

Charter Sections

- Purpose — why the Information Security Programme exists and how it supports GHC.
- Scope — assets, systems, data, people and third parties covered by the programme.
- Authority — source of authority, decision rights and escalation powers.
- Roles and Responsibilities — high-level governance accountabilities linked to Task 1.
- Key Principles — risk-based, business-aligned, proportionate and continuously improving security.
- Reporting Structure — management, committee and Board reporting expectations.
- Review and Approval — approval authority, review frequency and change control.

Required Evidence Task 2

5. Completed GHC Information Security Charter.
6. A 1–2 paragraph justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

SECTION	GHC INFORMATION SECURITY CHARTER
1. PURPOSE	This Charter formally establishes the Information Security Programme of GlobalHealth Connect (GHC). It ensures that information security and technology risks are managed as strategic business priorities with clear accountability across the organisation. The programme protects the confidentiality, integrity and availability of GHC information; protects patient information and customer trust; supports operational efficiency; enables secure innovation; and helps GHC meet applicable healthcare and data-protection obligations.

SECTION	GHC INFORMATION SECURITY CHARTER
2. SCOPE	PEOPLE: All GHC employees, contractors and other personnel who access GHC information or systems. SYSTEMS: Cloud-based patient-management systems, applications, databases, infrastructure and development environments. DATA: Patient, financial, employee, business and other sensitive information. THIRD PARTIES: Suppliers and service providers whose systems or services access GHC information or affect GHC operations. GOVERNANCE: Security governance, risk management, policies, compliance, awareness, incident response and security reporting.
3. AUTHORITY	Authorising Body: Board of Directors — provides strategic oversight of significant information security and enterprise risks. Executive Sponsor: Sarah Chen, CEO — provides executive direction and ensures security supports business objectives. Technology Leadership: Elena Rodriguez, CTO — provides technology and engineering input. Security Leader: CISO — leads the Information Security Programme, security governance and risk management. GRC Function: GRC Team — supports programme execution, risk assessments, compliance monitoring, policy management and reporting. Compliance: Mark Johnson, Compliance Officer — supports healthcare and data-protection compliance.
4. OBJECTIVES	a. Establish formal security governance with clear accountability. b. Protect patient information and maintain customer trust. c. Support expansion into two regional markets securely. d. Support operational efficiency and system reliability. e. Enable secure AI-driven diagnostics and data exchange. f. Meet applicable healthcare and data-protection obligations proactively. g. Provide meaningful security and risk information to management and the Board for decision-making and investment.
5. PRINCIPLES	a. Strategic Alignment — security supports GHC’s business objectives. b. Accountability — every security responsibility has a clearly assigned owner. c. Risk-Based — resources are prioritised according to risk. d. Proportionate — controls are appropriate to the level of risk and business requirements. e. Transparency — significant risks and incidents are reported accurately and promptly. f. Customer Trust — patient and sensitive information receives appropriate protection. g. Continual Improvement — the programme is regularly reviewed and improved.
6. REPORTING STRUCTURE	The CISO provides regular security and risk reports to executive management and the Security Steering Committee. Significant risks, major incidents and material compliance issues are escalated to the CEO and, where appropriate, the Board. Board reports focus on business impact, significant risks, trends, governance performance and investment priorities.
7. REVIEW CYCLE	The Charter is reviewed at least annually. An early review is triggered by a major security incident, significant regulatory change, acquisition, entry into a new market, major product change, significant technology change, material change in risk profile or significant audit finding.

SECTION	GHC INFORMATION SECURITY CHARTER
8. APPROVAL	Prepared by: CISO. Reviewed by: CEO, CTO, Compliance Officer and GRC Team. Approved by: CEO and Executive Management. Board Oversight: Board of Directors. Effective Date: 2026. Review Cycle: Annual or earlier when significant changes occur.

A 1–2 paragraph justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

JUSTIFICATION MEMO

To: Marcus Thorne, Chief Financial Officer

From: Chief Information Security Officer (CISO)

Subject: Justification for the GHC Information Security Charter

Date: 2026

The Information Security Charter provides GHC with a formal structure for managing information security as a business priority. It establishes clear accountability across the Board, CEO, CTO, CISO, Compliance Officer and GRC Team, ensuring that security risks have defined owners and are properly escalated. This supports GHC's goal of expanding its market share while protecting patient information and maintaining customer trust. It also supports operational efficiency by providing a consistent approach to managing security risks, and enables innovation in AI-driven diagnostics and secure data exchange without losing sight of security and regulatory requirements.

The Charter also improves the quality of security investment decisions by establishing a risk-based approach to allocating resources. Rather than responding to security issues on an ad-hoc basis, GHC can prioritise investments according to business impact, risk and strategic objectives. Regular reporting to executive management, the Security Steering Committee and the Board will provide visibility into security performance, significant risks, compliance issues and areas requiring investment. This gives management and the Board a clearer basis for deciding where security resources should be allocated while supporting GHC's objectives for growth, customer trust, operational efficiency, innovation and regulatory excellence.

Task 3 Board Reporting and Security Metrics

The Board has requested a concise, business-focused security update. Select the most decision-useful metrics from the six-month dataset, interpret the trends and present the organisation's security posture without unnecessary technical jargon.

Month	Phishing	Malware	Critical Vulns Patched	Patching %	Training %	High-Risk Incidents
September	150	25	10 of 15	67%	45%	2
October	180	30	12 of 20	60%	50%	3
November	210	35	15 of 25	60%	55%	4
December	250	40	18 of 30	60%	60%	5
January	280	45	20 of 35	57%	65%	6
February	320	50	22 of 40	55%	70%	7

Required Evidence Task 3

A one-page Board Executive Summary containing an overall Red/Amber/Green posture assessment and justification.

Reporting Period: September 2025 – February 2026

Overall Security Posture: ● **RED**

GHC's security posture is **Red** because the six-month trend shows increasing security exposure while key preventive controls are weakening. Phishing increased from **150 to 320**, malware increased from **25 to 50**, high-risk incidents increased from **2 to 7**, and critical vulnerability patching fell from **67% to 55%**. Although security awareness training improved from **45% to 70%**, it has not yet translated into a reduction in security incidents. The combination of rising threats, increasing high-risk incidents and declining patching performance indicates that GHC's current security controls require management attention.

The Board should prioritise improving vulnerability remediation, strengthening protection against phishing and malware, and reducing the number of high-risk incidents. Management should also investigate why threat levels are increasing despite improving training completion. Immediate action is recommended to improve patching performance, strengthen security controls and ensure that security resources are directed toward the highest business risks.

Five selected security metrics showing current status, six-month trend and concise business commentary.

Metric	September	February	6-Month Trend	Business Commentary
Phishing	150	320	Increasing	Phishing more than doubled, increasing the likelihood of compromised accounts, fraud and disruption.
Malware	25	50	Increasing	Malware doubled, indicating increasing exposure to malicious activity and potential operational disruption.
Critical Vulnerabilities Patched	10/15 (67%)	22/40 (55%)	Declining	A smaller proportion of critical vulnerabilities is being remediated, increasing exposure to preventable security incidents.
Training Completion	45%	70%	Improving	Training participation is improving, but 30% of personnel remain untrained and the increase in incidents shows that further improvement is needed.
High-Risk Incidents	2	7	Increasing	High-risk incidents more than tripled, indicating increasing potential for serious business, customer and reputational impact.

At least two priority risks/issues and two actionable recommendations.

Metric	September → February	Direction
Phishing	150 → 320	● ↑
Malware	25 → 50	● ↑
Critical vulnerabilities patched	67% → 55%	● ↓
Training completion	45% → 70%	□ ↑
High-risk incidents	2 → 7	● ↑

A short rationale explaining why your five selected metrics are suitable for Board oversight.

Priority Risk 1 — Increasing Security Incidents

Risk: High-risk incidents increased from **2 to 7**, while phishing and malware also increased significantly.

Business impact: Increased possibility of disruption, loss of sensitive information, customer trust issues and regulatory consequences.

Recommendation: Strengthen phishing and malware prevention controls, investigate the causes of the increasing incidents, and provide targeted awareness training based on identified weaknesses.

Priority Risk 2 — Declining Critical Vulnerability Patching

Risk: The proportion of critical vulnerabilities patched declined from **67% to 55%**, despite the number of critical vulnerabilities increasing.

Business impact: Unpatched critical vulnerabilities create avoidable exposure to security incidents and operational disruption.

Recommendation: Establish a management-monitored critical vulnerability remediation target, assign clear ownership for overdue vulnerabilities and escalate significant remediation delays to the CISO and Security Steering Committee.

A short rationale explaining why your five selected metrics are suitable for Board oversight.

These five metrics provide the Board with a balanced view of GHC's security posture. **Phishing and malware** show the level of external security pressure facing the organisation, while **critical vulnerability patching** measures the effectiveness of an important preventive control. **Training completion** provides visibility into employee security awareness, and **high-risk incidents** shows whether security threats are translating into serious events. Together, the metrics allow the Board to see **threat exposure, control effectiveness, human-risk improvement and actual security impact**. They are therefore more useful for Board oversight than a collection of highly technical operational measures.

Task 4 Security Steering Committee

A dispute has emerged between the CTO and IT Manager regarding a proposed password policy. The CTO believes the policy will create excessive friction; the IT Manager argues that stronger controls are necessary. The CEO wants a formal Security Steering Committee (SSC) to resolve such cross-functional issues.

Conflict context: The proposed policy requires 16-character complex passwords changed every 30 days without password-manager integration. The CTO recommends a more balanced approach emphasising multi-factor authentication and secure password-management.

Required Evidence Task 4

7. Security Steering Committee Terms of Reference covering purpose, scope, membership, responsibilities, meeting cadence, decision authority and reporting.

SECTION	DETAIL
1. Purpose	Establish a formal cross-functional Security Steering Committee (SSC) to provide strategic direction, prioritise security initiatives, oversee information security risks and resolve conflicts between security, technology and business requirements.
2. Scope	Information security governance, security risks, policies, compliance, security investments, major incidents, security performance and cross-functional security decisions.
3. Membership	Chair: CEO – Sarah Chen. Members: CTO – Elena Rodriguez; CISO; Compliance Officer – Mark Johnson; GRC Team representative; IT Manager – John Smith; CFO – Marcus Thorne where financial or investment decisions are required.
4. Responsibilities	Review significant security risks; approve or recommend security priorities; review security policies; oversee security performance and KPIs; review major incidents; support regulatory compliance; resolve cross-functional security disputes; review security investment requirements.
5. Meeting Cadence	Monthly, with additional meetings when a major security incident, significant risk or urgent governance decision requires attention.

6. Decision Authority	The SSC may make decisions within its delegated authority and recommend major decisions to the CEO or Board. Decisions shall be based on risk, business impact, regulatory requirements and GHC's strategic objectives.
7. Reporting	The CISO shall provide security risk, incident, compliance and performance information to the SSC. Significant risks and decisions requiring executive or Board oversight shall be escalated appropriately.
8. Quorum	The Chair or delegated executive representative, CISO and at least two other core members must be present for formal decisions.
9. Records	Meeting decisions, actions, owners and deadlines shall be documented and maintained by the GRC Team.
10. Review	The Terms of Reference shall be reviewed annually or following significant organisational, regulatory or security changes.

8. A sample agenda for the first SSC meeting with the password-policy conflict as a key discussion item.

TIME	AGENDA ITEM	LEAD
10:00-10:05	Welcome and opening	CEO
10:05-10:10	Confirm SSC purpose, membership and decision authority	CEO
10:10-10:20	Review current GHC security governance risks	CISO
10:20-10:35	Password Policy Conflict: 16-character passwords every 30 days vs. balanced MFA/password-management approach	CTO & IT Manager
10:35-10:45	Risk and business-impact assessment of proposed approaches	CISO / GRC Team

10:45- 10:55	Regulatory and compliance considerations	Compliance Officer
10:55 -11:05	SSC decision and agreed direction	CEO / SSC
11:05-11:10	Actions, owners and deadlines	GRC Team
11:10-11:15	Any other business and next meeting	CEO

Decision criteria for the password-policy issue

The SSC should compare the options based on:

1. Security risk reduction
2. User/business impact
3. Regulatory requirements
4. Operational practicality
5. Cost and resource requirements
6. Alignment with GHC's strategic objectives

The scenario says the proposed policy requires **16-character complex passwords changed every 30 days without password-manager integration**, while the CTO proposes greater emphasis on **MFA and secure password management**.

9. A 1–2 paragraph briefing note to the CEO explaining how the SSC will resolve cross-functional conflict and maintain strategic alignment.

BRIEFING NOTE

To: Sarah Chen, Chief Executive Officer

From: Chief Information Security Officer (CISO)

Subject: Security Steering Committee and Resolution of Password Policy Conflict

Date: 2026

The proposed Security Steering Committee (SSC) will provide GHC with a formal mechanism for resolving cross-functional security decisions while maintaining alignment with business objectives. Rather than allowing security and technology disagreements to be resolved informally, the SSC will bring the relevant stakeholders together to assess risks, business impact, regulatory requirements, operational practicality and investment implications. The committee will provide clear decision-making and escalation routes while ensuring that significant matters can be referred to executive management or the Board.

The password-policy disagreement demonstrates the value of this structure. The SSC can evaluate the IT Manager's concern about stronger controls alongside the CTO's concern about excessive user friction and consider a balanced risk-based approach. The decision should consider the effectiveness of authentication controls, the impact on employees and operations, and GHC's overall risk appetite and strategic objectives. This approach allows GHC to strengthen security without unnecessarily restricting productivity or innovation.

Task 5 Governance Maturity Assessment

The Board wants evidence that the new governance arrangements will improve over time. Assess GHC's current maturity using the simplified 1–5 model below and propose a realistic roadmap to achieve at least Level 3 (Defined) across all domains within 12–18 months.

Current-State Interview Summary

Governance Domain	Current-State Evidence
Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.
Roles & Responsibilities	Security ownership and accountability are unclear.
Risk Management	The organisation is reactive and lacks a formal proactive assessment process.
Metrics & Reporting	Technical metrics exist, but they are not consistently translated into business impact.
Training & Awareness	Annual training is mandatory, but engagement is low.
Compliance	Preparation is audit-driven rather than continuously monitored.

Simplified Maturity Scale

Level	Description
1 – Ad Hoc	Informal, reactive and inconsistent; no defined processes.
2 – Initial	Some processes exist but are inconsistently documented or applied.
3 – Defined	Processes are documented, standardised, communicated and supported by clear responsibilities.
4 – Managed	Processes are measured, monitored and reviewed against performance targets.
5 – Optimising	Continuous improvement is embedded and processes adapt quickly to changing risk.

Required Evidence Task 5

10. A completed maturity assessment for Policy & Documentation, Roles & Responsibilities, Risk Management, Metrics & Reporting, Training & Awareness, and Compliance.

NO	GOVERNANCE DOMAIN	CURRENT EVIDENCE AT GHC	CURRENT LEVEL	WHY	TARGET
1	Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.	2 – Initial	Some policies exist, but they are inconsistent and not consistently maintained.	3 – Defined

2	Roles & Responsibilities	Security ownership and accountability are unclear.	1 – Ad Hoc	Responsibilities are not clearly defined or consistently assigned.	3 – Defined
3	Risk Management	GHC is reactive and lacks a formal proactive assessment process.	1 – Ad Hoc	Risk management is mainly reactive rather than structured and proactive.	3 – Defined
5	Metrics & Reporting	Technical metrics exist but are not consistently translated into business impact.	2 – Initial	Metrics exist, but reporting is not yet consistently business-focused.	3 – Defined
6	Training & Awareness	Annual training is mandatory, but engagement is low.	2 – Initial	A formal training process exists, but participation and engagement need improvement.	3 – Defined
7	Compliance	Preparation is audit-driven rather than continuously monitored.	2 – Initial	Compliance activities exist but are largely reactive and audit-focused.	3 – Defined

11. A 12–18 month maturity roadmap containing 3–5 priority initiatives. For each initiative, state the objective, key activities and measurable expected outcome.

INITIATIVE	OBJECTIVE	KEY ACTIVITIES	EXPECTED MEASURABLE OUTCOME	TIMELINE
1. Formalise Governance Framework & Policies	Establish consistent governance and documentation.	Adopt governance framework; review existing policies; remove acquisition inconsistencies; approve and publish core policies.	100% of critical security policies documented, approved and reviewed.	Months 1–4

2. Establish Security Roles, RACI & GRC Function	Create clear security ownership and accountability.	Formalise CISO role; establish GRC function; develop RACI; define governance responsibilities and escalation paths.	100% of key governance activities have a named Accountable owner.	Months 1–4
3. Implement Formal Risk Management	Move GHC from reactive to proactive risk management.	Establish risk methodology; create risk register; conduct regular risk assessments; define risk appetite; track remediation.	Formal risk register established and reviewed at least quarterly.	Months 3–8
4. Improve Metrics, Reporting & Awareness	Improve Board visibility and employee security engagement.	Establish Board KPIs; create regular security reporting; improve awareness programme; introduce role-based awareness activities.	Quarterly Board security reporting established and training completion reaches $\geq 90\%$.	Months 5–12
5. Establish Continuous Compliance Monitoring	Move from audit-driven compliance to proactive monitoring.	Map applicable obligations; assign compliance owners; establish monitoring schedule; maintain evidence; report compliance gaps.	Compliance monitoring performed regularly with documented evidence and tracked remediation.	Months 8–18

Roadmap Logic

Months 1–4: Build the foundation — governance structure, policies, roles and accountability.

Months 3–8: Establish proactive risk management and formal risk oversight.

Months 5–12: Strengthen Board reporting, KPIs and security awareness.

Months 8–18: Embed continuous compliance monitoring and move toward sustainable Level 3 maturity.

This sequencing is realistic because GHC should first establish **who owns security and how governance works**, before trying to measure and continuously improve it.

A 1–2 paragraph executive summary to the Board explaining GHC's current maturity and the strategic importance of the roadmap.

BOARD EXECUTIVE SUMMARY

GHC Governance Maturity Assessment

Overall Current Maturity: ☐ **AMBER — Level 2 (Initial)**
Target Maturity: ☐ **Level 3 (Defined) within 12–18 months**

GHC's current information security governance maturity is assessed as approximately **Level 2 – Initial**, with significant elements still operating at Level 1 – Ad Hoc. The assessment shows that GHC has some security and governance processes in place, but they are not yet consistently documented, standardised or supported by clear accountability. The most significant weaknesses are unclear security ownership, reactive risk management, inconsistent policies, limited business-focused reporting, low training engagement and audit-driven compliance. These weaknesses are particularly important given GHC's rapid growth, acquisitions and recent data-leakage near-miss.

The proposed 12–18 month roadmap focuses on establishing a formal governance framework, clarifying security responsibilities, implementing proactive risk management, improving metrics and awareness, and establishing continuous compliance monitoring. Achieving Level 3 – Defined will give GHC documented and standardised governance processes with clear responsibilities and more consistent oversight. This will support the organisation's growth into new markets, protect customer trust and patient information, enable secure innovation and provide the Board with greater confidence that security risks are being identified, managed and reported appropriately.